

Vulnerability Assessment Report

Target: testphp.vulnweb.com

Date: June 15, 2026

Classification: Confidential

Prepared for: Future Interns Program

This document contains confidential information. Unauthorized distribution prohibited.

1. Executive Summary

A comprehensive assessment of **testphp.vulnweb.com** identified **10 vulnerabilities** (2 Critical, 3 High, 3 Medium, 2 Low). Key risks include SQL Injection enabling database compromise, Cross-Site Scripting for session hijacking, and Local File Inclusion for server file access. Business impacts range from data breaches and account takeover to compliance violations (GDPR, PCI-DSS).

Risk Level	Count	Business Impact
Critical	2	Direct database compromise; full data access
High	3	Account takeover, server file access, session hijacking
Medium	3	Clickjacking, CSRF, missing security controls
Low	2	Information disclosure aiding attacker reconnaissance

2. Scope & Target Information

Attribute	Details
Target URL	http://testphp.vulnweb.com
Target Type	Deliberately vulnerable web application (Acunetix)
IP Address	44.228.249.3
Web Server	nginx 1.19.0 / Apache + PHP
Open Ports	80/tcp (HTTP)
Assessment Date	June 15, 2026
Methodology	OWASP Testing Guide v4, PTES, CVSS v3.1

3. Findings Overview

#	Vulnerability	Severity	CVSS	Location
1	SQL Injection - Login Bypass	Critical	9.8	/login.php
2	Hardcoded Credentials Exposure	Critical	9.1	/pictures/credentials.txt
3	SQL Injection - Search Field	High	8.6	/search.php?searchFor=
4	Reflected XSS	High	6.1	/listproducts.php?cat=
5	Local File Inclusion	High	7.5	/showimage.php?file=

6	Missing CSP Header	Medium	5.0	Global
7	Missing Anti-Clickjacking Header	Medium	4.5	Global
8	Absence of Anti-CSRF Tokens	Medium	4.3	/login.php
9	Server Information Disclosure	Low	2.5	HTTP Headers
10	Directory Indexing Enabled	Low	3.3	/pictures/

4. Detailed Vulnerability Findings

F-01: SQL Injection - Login Bypass

Attribute	Details
Severity	Critical
CVSS v3.1	9.8
CWE	CWE-89
Location	/login.php

Technical Description:

The login page accepts raw user input in username/password fields without sanitization. An attacker can bypass authentication by injecting SQL meta-characters (e.g., ' OR '1'=1), altering the SQL query to always return true and granting admin access.

Business Impact:

This flaw lets attackers log in as any user without knowing passwords. This is like having a master key to every account — enabling data theft, content manipulation, and system compromise.

Remediation:

- 1. Use parameterized prepared statements (PDO/MySQLi)
- 2. Implement strict input validation
- 3. Apply least privilege to DB accounts
- 4. Deploy a WAF

F-02: Hardcoded Credentials Exposure

Attribute	Details
Severity	Critical
CVSS v3.1	9.1
CWE	CWE-798

Location	/pictures/credentials.txt
----------	---------------------------

Technical Description:

A publicly accessible text file at /pictures/credentials.txt contains plaintext credentials. Directory indexing on /pictures/ makes this file easily discoverable.

Business Impact:

Equivalent to taping your office key and alarm code to the front door. Anyone can find valid login credentials and take over accounts immediately.

Remediation:

- 1. Immediately remove credentials.txt
- 2. Disable directory listing (Options -Indexes)
- 3. Audit all public directories
- 4. Never store credentials in web root

F-03: SQL Injection - Search Field

Attribute	Details
Severity	High
CVSS v3.1	8.6
CWE	CWE-89
Location	/search.php?searchFor=

Technical Description:

The search functionality passes user input directly into SQL queries without sanitization. SQLmap confirmed ability to enumerate databases, tables, and extract user credentials.

Business Impact:

Attackers can use the search box to steal the entire database. This commonly leads to public data breaches involving customer names, emails, and passwords.

Remediation:

- 1. Use parameterized queries for all DB operations
- 2. Whitelist-based input validation
- 3. Restrict DB permissions to read-only
- 4. Regular code reviews

F-04: Reflected Cross-Site Scripting (XSS)

Attribute	Details
Severity	High

CVSS v3.1	6.1
CWE	CWE-79
Location	/listproducts.php?cat=

Technical Description:

User input in the 'cat' parameter is reflected in HTTP responses without encoding. Payloads like alert('XSS') execute in victim browsers.

Business Impact:

Attackers can inject malicious scripts to steal session cookies, redirect users to phishing pages, or perform actions as the victim — enabling full account takeover.

Remediation:

- 1. Context-aware output encoding (htmlspecialchars)
- 2. Implement CSP headers
- 3. HttpOnly + Secure session cookies
- 4. Input validation on all user data

F-05: Local File Inclusion (LFI)

Attribute	Details
Severity	High
CVSS v3.1	7.5
CWE	CWE-98
Location	/showimage.php?file=

Technical Description:

The 'file' parameter accepts user paths without validation. Path traversal (../../../../etc/passwd) reads arbitrary server files including configs with DB credentials.

Business Impact:

Attackers can read password files, database configs, and source code. This exposes the entire server infrastructure and often leads to full compromise.

Remediation:

- 1. Whitelist allowed file paths
- 2. Strip path traversal sequences
- 3. Minimal filesystem permissions
- 4. Disable unsafe PHP functions

F-06: Missing Content Security Policy

Attribute	Details
Severity	Medium
CVSS v3.1	5.0
CWE	CWE-1021
Location	Global - All Pages

Technical Description:

No CSP header is set. This defense-in-depth mechanism restricts which content sources the browser can load, significantly reducing XSS impact.

Business Impact:

Without CSP, there are no browser barriers against malicious script execution. Any injection point can be used to load external attack scripts and steal data.

Remediation:

- 1. Add: Content-Security-Policy: default-src 'self'
- 2. Use CSP reporting to monitor violations
- 3. Avoid 'unsafe-inline' in production
- 4. Test in report-only mode first

F-07: Missing Anti-Clickjacking Header

Attribute	Details
Severity	Medium
CVSS v3.1	4.5
CWE	CWE-1021
Location	Global - All Pages

Technical Description:

X-Frame-Options header is missing. Attackers can embed the site in an iframe on malicious pages to trick users into performing actions unknowingly.

Business Impact:

Clickjacking lets attackers trick users into clicking buttons they can't see — like deleting accounts or approving transactions without consent.

Remediation:

- 1. Add X-Frame-Options: DENY or SAMEORIGIN
- 2. Or use frame-ancestors 'none' in CSP
- 3. Apply frame-busting JavaScript

F-08: Absence of Anti-CSRF Tokens

Attribute	Details
Severity	Medium
CVSS v3.1	4.3
CWE	CWE-352
Location	/login.php, /secured/newuser.php

Technical Description:

State-changing forms lack unique CSRF tokens. Attackers can craft malicious pages that submit valid requests on behalf of authenticated users.

Business Impact:

Without CSRF protection, attackers can trick users into changing passwords or creating accounts unknowingly. Like someone forging your signature on a document.

Remediation:

- 1. Implement CSRF tokens on all state-changing forms
- 2. Use Synchronizer Token Pattern
- 3. Validate server-side
- 4. Set SameSite=Strict on cookies

F-09: Server Information Disclosure

Attribute	Details
Severity	Low
CVSS v3.1	2.5
CWE	CWE-200
Location	HTTP Response Headers

Technical Description:

Headers leak 'X-Powered-By: PHP/5.x' and 'Server: nginx/1.19.0', helping attackers tailor exploits to specific versions.

Business Impact:

Revealing server details helps attackers pick the right tools. Like wearing a badge saying 'I use Lock Model X' — it helps thieves prepare.

Remediation:

- 1. expose_php = Off in php.ini
- 2. server_tokens off in nginx
- 3. Custom error pages

- 4. Reverse proxy to strip headers

F-10: Directory Indexing Enabled

Attribute	Details
Severity	Low
CVSS v3.1	3.3
CWE	CWE-548
Location	/pictures/

Technical Description:

Directory listing is enabled on /pictures/, allowing browsing of all files. Combined with exposed credentials.txt, risk is significantly elevated.

Business Impact:

Directory listing is like leaving your filing cabinet open. Visitors can see all files, often revealing backups, configs, or credentials.

Remediation:

- 1. Options -Indexes (Apache) or autoindex off (nginx)
- 2. Add index.php/index.html files
- 3. Full directory audit

5. Risk Classification Summary

Severity	CVSS Range	Count	Definition
Critical	9.0-10.0	2	Direct system compromise. Immediate remediation required.
High	7.0-8.9	3	Significant breach risk. Remediation within 7 days.
Medium	4.0-6.9	3	Moderate risk. Address within 30 days.
Low	0.1-3.9	2	Minimal direct risk but enables severe attacks. Address within 90 days.

6. Remediation Roadmap

P0 - Critical (0-7 Days)

- **SQL Injection:** Implement prepared statements across all DB queries
- **Remove exposed credentials:** Delete credentials.txt, disable directory indexing

P1 - High (7-30 Days)

- **Fix XSS:** Output encoding + CSP headers
- **Fix LFI:** Whitelist-based file mapping
- **CSRF tokens:** Add to all forms

P2 - Medium (30-60 Days)

- **Security Headers:** CSP, X-Frame-Options, X-Content-Type-Options
- **HTTPS:** Migrate with TLS 1.2+ and HSTS

P3 - Low (60-90 Days)

- **Info Disclosure:** Disable server banners, custom error pages
- **Security Testing:** Integrate SAST/DAST in CI/CD
- **Training:** OWASP Top 10 developer training

Priority	Findings	Timeline	Effort
P0 - Critical	F-01, F-02	0-7 days	2-3 days
P1 - High	F-03, F-04, F-05	7-30 days	3-5 days
P2 - Medium	F-06, F-07, F-08	30-60 days	1-2 days
P3 - Low	F-09, F-10	60-90 days	0.5-1 day

7. Conclusion

The assessment of **testphp.vulnweb.com** found 10 vulnerabilities (2 Critical, 3 High, 3 Medium, 2 Low). The most critical are SQL Injection in login/search and exposed credentials, which enable complete database compromise with minimal effort.

Key strategic recommendations:

- Parameterized queries for all database operations
- Comprehensive security headers (CSP, X-Frame-Options)
- Secure development lifecycle with automated testing
- Regular OWASP Top 10 developer training
- Recurring vulnerability assessments